

Monitoring Use Case: TCP Port Scan Detection

Use Case ID: IDS-001

Technology: Suricata IDS

Monitored Asset: Kali Linux VM

IP Address: 192.168.64.2

Interface: eth0

Detection: Excessive TCP SYN packets

Purpose: Will detect possible network reconnaissance or port-scanning activity.

Detection Rule

```
alert tcp any any -> $HOME_NET any (msg:"LOCAL ALERT: Possible TCP Port Scan"; flags:S; threshold:type both,track by_src,count 20,seconds 5; classtype:attempted-recon; sid:1000001; rev:1;)
```

Detection Logic

The rule will generate an alert when a source sends at least 20 TCP SYN packets within five seconds toward the monitored network.

Security Significance

Port scanning is commonly associated with reconnaissance. An attacker may scan a system to determine which ports and services are available before attempting exploitation.

This directly relates to the project's Nmap vulnerability assessment, where service enumeration identified exposed services including SSH and HTTP.

Create the alert prioritization process

Will use a simple three-level system:

Priority	Description	Example
Critical	Evidence of active exploitation or compromise	Successful exploitation attempt
High	Strong indication of malicious activity	Large/rapid port scan against critical asset

Medium	Suspicious activity requiring investigation	Limited port scan
Low	Informational or expected activity	Authorized security scan

test incident:

Alert Priority: High

Why?

The activity resembles reconnaissance against a monitored system. A port scan by itself does not prove compromise, but it may indicate preparation for a subsequent attack.

Response steps

1. Validate

Determine whether the alert was generated by an authorized security scan or unexpected activity.

2. Identify the source

Record:

- Source IP
- Destination IP
- Timestamp
- Number of connection attempts
- Ports targeted

3. Determine authorization

If the scan came from an approved security assessment, document it as authorized activity.

If it was unexpected, treat it as a potential security incident.

4. Contain

If malicious activity is confirmed, block or restrict the source through the firewall or network controls.

5. Investigate

Review:

/var/log/suricata/fast.log

and:

/var/log/suricata/eve.json

Look for additional suspicious traffic.

6. Check for compromise

Perform additional vulnerability and service checks on the affected system.

7. Remediate

Patch vulnerable services and restrict unnecessary network exposure.

8. Document

Record what happened, how it was detected, what actions were taken, and whether additional controls are needed.

Incident: Unauthorized Port-Scanning Activity

Incident classification

Category: Network reconnaissance

Severity: High

Status: Detected / Under Investigation

Scenario

Suricata detected an unusually high number of TCP SYN packets directed toward the Kali Linux VM. The activity exceeded the configured threshold of 20 TCP SYN packets within five seconds. The activity was classified as possible port-scanning behavior because it resembled reconnaissance used to identify accessible network services.

Response

1. Suricata generated an alert.
2. The alert was reviewed and prioritized as High.
3. The source IP was identified.
4. The activity was checked against authorized testing activity.

5. Suricata logs were reviewed for additional activity.
 6. The affected system's exposed services were reviewed.
 7. Nmap was used as a vulnerability-assessment tool to determine whether exposed services required remediation.
 8. If unauthorized activity had been confirmed, the source would be blocked through network controls.
 9. The incident and response actions were documented.
-

14. Lessons Learned

The incident demonstrated the value of continuous security monitoring in addition to periodic vulnerability assessments. Nmap can identify exposed services and potential vulnerabilities during an assessment, while Suricata provides ongoing monitoring for suspicious network activity. Combining the two approaches allows identified risks to be monitored after the initial assessment and provides an additional mechanism for detecting reconnaissance activity.

The exercise demonstrated that detection rules must be tuned to reduce false positives. Authorized vulnerability scans can generate alerts that resemble malicious reconnaissance, so security analysts must determine whether an alert represents approved testing or unauthorized activity before escalating it as an incident.